

Checklist OWASP Top 10 (2021)

Riesgo	¿Aplica?	Mitigación actual
A01: Broken Access Control	Sí (APIs)	JWT para autenticación; rutas tras gateway; controles en servicios (auth, config, etc.); WAF bloquea UAs maliciosos; no exponer DB al host.
A02: Cryptographic Failures	Sí	TLS en gateway con redirección HTTPS; HSTS/CSP/XFO/XCTO; secretos en <code>.env</code> (plantilla <code>.env.example</code>); recomendación de rotación de claves; evitar hardcodeo.
A03: Injection (SQL/Command)	Sí	Uso de ORM/queries parametrizadas en servicios Node; WAF bloquea agentes conocidos (sqlmap); DB no expuesta; logs centralizados para detectar patrones 401/403/429.
A04: Insecure Design	Parcial	Arquitectura en microservicios con separación de roles; hardening de contenedores (no-root, drop de capabilities); falta documentar casos de abuso/amenazas; plan de políticas pendiente.
A05: Security Misconfiguration	Sí	<code>security_opt: no-new-privileges; cap_drop: [ALL]</code> ; imágenes versionadas; puertos internos no publicados; headers de seguridad en Nginx; excepciones documentadas para Nginx root; falta pipeline de parches continuo.
A06: Vulnerable/Outdated Components	Sí	CVEs identificados con Docker Scout (<code>analisis/post-hardening/MDs</code>); versiones fijadas (node:18.18.2-alpine, postgres:15-alpine, nginx:alpine); falta pipeline de actualización/escaneo recurrente.
A07: Identification and Authentication Failures	Sí	JWT en auth-service; rate limiting en gateway; no exposición de DB; falta MFA para paneles; revisar expiración/rotación de tokens.
A08: Software and Data Integrity Failures	Parcial	Imágenes construidas con multi-stage; sin supply-chain signing; sin SBOM ni firmas; recomendación: cosign/attestations, checksum de dependencias.
A09: Security Logging and Monitoring Failures	Sí	Centralización con Loki/Promtail/Grafana; etiquetas por servicio; parseo de logs del gateway; pendiente definir retención formal y alertas de seguridad.
A10: Server-Side Request Forgery (SSRF)	Parcial	Gateway limita destinos a upstreams definidos; contenedores en redes internas; sin metadata service accesible; falta validación explícita de URLs de salida en servicios que hagan requests a terceros.